

Resumo para prova

Segurança e Auditoria de Sistemas de Informação

Capítulo 1 — Fundamentos de segurança e auditoria de sistemas de informação

Baseado em: TERUEL, Evandro Carlos. Segurança e auditoria de sistemas de informação. São Paulo: Editora Senac São Paulo, 2026.

O que cai na prova (visão geral)

- Conceito de segurança da informação (ISO/IEC 27000) e seus 7 princípios.
- Mnemônico **CIDAL**: Confidencialidade, Integridade, Disponibilidade, Autenticidade, Legalidade.
- Princípios complementares: Não repúdio e Rastreabilidade.
- Conceito de auditoria de sistemas (ISO 19011) e de auditoria de SI.
- 5 benefícios da auditoria de sistemas de informação.
- Aplicação proporcional dos princípios (baseada em análise de riscos - ISO/IEC 27005).
- Contexto histórico: auditoria x segurança da informação.

1. Conceito de segurança da informação

Segundo a norma **ISO/IEC 27000** (ISO, 2014), segurança da informação é a proteção da **confidencialidade, integridade e disponibilidade** das informações, ancorada em pilares adicionais como autenticidade, legalidade, não repúdio e rastreabilidade.

Refere-se ao conjunto de práticas, políticas e medidas para proteger ativos digitais (dados, sistemas, redes, dispositivos) contra acessos não autorizados, alterações inadequadas, interrupções ou destruições — acidentais ou intencionais. Objetivo: garantir confiança nas operações, continuidade do negócio e conformidade legal.

Mnemônico CICAL

Os 3 princípios clássicos (CIA/CID) + 2 adicionados por algumas fontes formam o acrônimo **CICAL**:

Letra	Princípio	Ideia-chave
C	Confidencialidade	Só quem é autorizado acessa a informação
I	Integridade	Dados completos e sem alteração indevida
D	Disponibilidade	Sistema acessível quando necessário
A	Autenticidade	Identidade/mensagem é genuína e verificável
L	Legalidade	Conformidade com leis e normas (ex.: LGPD)

Atenção: Não repúdio e Rastreabilidade **não entram na sigla CICAL** — são citados como princípios **complementares**, essenciais para auditoria e responsabilização.

2. Os princípios em detalhe

2.1 Confidencialidade

Impede que a informação seja acessada/divulgada a pessoas ou processos não autorizados (ISO, 2014).

- Controle de acesso baseado em papéis/cargos: **RBAC**.
- Autenticação robusta: senhas fortes + **MFA/2FA** (múltiplos fatores).
- **Criptografia** em trânsito e em repouso (ex.: criptografia assimétrica usa a chave pública do destinatário para cifrar a mensagem).

2.2 Integridade

Garante que os dados permaneçam intactos, completos e fidedignos durante todo o ciclo de vida (criação, armazenamento, processamento, transmissão, descarte).

- **Hash** (valor hash/resumo) funciona como "impressão digital" do dado — qualquer alteração muda o hash.
- Gestão de versões de documentos (rastreia quem alterou o quê).
- **FIM** (File Integrity Monitoring) — monitora arquivos críticos e alerta sobre alterações não autorizadas.

2.3 Disponibilidade

Garante que sistemas, serviços e dados estejam acessíveis e operacionais quando necessário, de forma confiável.

- Infraestrutura **redundante** (duplicação de servidores, conexões, storage).
- **Backups** regulares em locais seguros.
- **DRP** — Plano de Recuperação de Desastres.

- Monitoramento contínuo da saúde dos sistemas (CPU, tráfego de rede, etc.).

2.4 Autenticidade

Qualidade de algo reconhecido como verdadeiro, verificável e confiável; confirma a legitimidade da identidade do emissor de uma mensagem ou comunicação.

- Mecanismo principal: **assinatura digital** (usa criptografia assimétrica — o autor assina o hash da mensagem com sua chave privada; o receptor confere com a chave pública do autor).
- Reforçada por **MFA**: algo que o usuário sabe (senha) + tem (token/dispositivo) + é (biometria).

2.5 Não repúdio (irretratabilidade)

Impede que alguém negue ter realizado uma ação (criação de dado, troca de mensagem, validação de registro).

- **Assinaturas digitais** — prova criptográfica incontestável de autoria.
- **Logs** detalhados e protegidos das operações realizadas.
- Confirmações formais de envio/recebimento (recibos digitais, avisos automáticos).

2.6 Rastreabilidade

Possibilidade de identificar qual usuário realizou cada ação crítica para a segurança dos sistemas.

- Ligada ao **princípio do privilégio mínimo** (dar apenas as permissões necessárias).
- Depende de **logs detalhados** (tentativas de acesso, mudanças em dados, comandos administrativos).
- Ferramentas: **SIEM** (Security Information and Event Management) — correlaciona e analisa logs, gera alertas em tempo real.

2.7 Legalidade

Respeito a leis, regulamentos e normas no manejo dos dados, da coleta ao descarte.

- Principais marcos legais no Brasil: **LGPD** (Lei 13.709/2018) e **Marco Civil da Internet** (Lei 12.965/2014).
- Internacionais: **GDPR** (Europa), **Cyber Resilience Act** (Europa), **PIPEDA** (Canadá), **Data Security Law** (China), **CCPA** (Califórnia/EUA).
- Conceito de "**privacy by design**" / **privacidade desde a concepção e por padrão**.

3. Aplicação dos princípios

Pergunta clássica de prova: **é preciso implementar todos os princípios em toda empresa? Não, obrigatoriamente não.** A aplicação deve ser **proporcional ao contexto** (tipo de informação, ambiente, regulamentações aplicáveis).

O procedimento recomendado começa com uma **avaliação formal de riscos**, conforme a norma **NBR ISO/IEC 27005**, que deve incluir: identificação dos ativos de informação, avaliação de ameaças e vulnerabilidades, e estimativa de probabilidade/impacto de incidentes (Nist, 2012). A escolha dos controles deve ser fundamentada nos riscos identificados (NIST SP 800-53 rev. 5).

4. Auditoria de sistemas de informação

Definição geral de auditoria (ISO 19011)

Auditoria é um processo **organizado, independente e registrado** que visa coletar e analisar provas objetivas, a fim de averiguar se os critérios de auditoria (requisitos padrão) estão sendo cumpridos. É uma prática **sistemática e imparcial**.

Analogia da prova (mecânico)

- Auditor = mecânico. Critérios de auditoria = lista de verificação. Evidências = freios, pneus, óleo.
- O auditor **não conserta** o carro — apenas aponta se está tudo em ordem ou quais problemas existem.

Auditoria de sistemas de informação (definição específica)

Procedimento metódico, realizado por profissionais qualificados, para examinar e avaliar os controles de um sistema de informação, confirmando se ele apoia adequadamente os ativos e metas da empresa.

Avalia: **integridade, disponibilidade, confidencialidade, conformidade, eficácia e usabilidade** do sistema — da entrada/processamento até a saída dos dados.

5. Os 5 benefícios da auditoria de SI

Tema muito provável em prova — memorizar os 5 nomes e a ideia central de cada um:

1. Redução de riscos

Descobre, analisa e reduz riscos de proteção/acessibilidade dos dados. Ex.: encontrar servidores com credenciais padrão ou portas abertas. Usa scanners de vulnerabilidade (ex.: Nessus), analisadores de log, avalia firewalls e IDS.

2. Aprimoramento da segurança de dados

Detecta controles fracos ou inexistentes, melhora a proteção de dados sensíveis (clientes, propriedade intelectual, dados financeiros). Ex.: verificar criptografia de dados em trânsito, estratégias de backup.

3. Governança e conformidade

Verifica se métodos, controles e práticas de TI estão organizados e alinhados aos objetivos estratégicos. Checa adesão a leis nacionais/internacionais (LGPD, GDPR).

4. Eficiência operacional

Detecta ineficiências: processos manuais desnecessários, sistemas defasados, permissões administrativas indevidas. Ferramentas: Active Directory (IAM), BPMN (mapeamento de processos).

5. Visão externa imparcial

Auditores externos oferecem avaliação objetiva, livre de conflitos de interesse da rotina interna. Usam metodologias reconhecidas (ex.: OWASP Top 10).

6. Contexto histórico

Auditoria e segurança da informação têm **origens diferentes**, mas suas trajetórias se entrelaçaram: a auditoria existe desde a **Idade Média** (verificação de contas do governo) e se firmou no setor empresarial; com a revolução tecnológica, passou a incluir sistemas de informação e segurança digital. Hoje, **auditoria e segurança da informação operam em conjunto** na defesa contra riscos e ameaças digitais.

7. Normas e leis mais citadas (guarde os nomes)

Norma/Lei	Sobre o quê
ISO/IEC 27000:2014	Conceitos e vocabulário de segurança da informação
ISO/IEC 27001:2024	Requisitos para sistema de gestão de segurança da informação
ISO/IEC 27002:2022	Controles de segurança da informação
ISO/IEC 27701:2019	Extensão da 27001/27002 para gestão da privacidade
ISO/IEC 27005:2023	Gestão de riscos de segurança da informação
ISO 19011:2018	Diretrizes para auditoria de sistemas de gestão
NIST SP 800-53 rev.5	Controles de segurança e privacidade
LGPD (Lei 13.709/2018)	Lei Geral de Proteção de Dados (Brasil)
Marco Civil da Internet (Lei 12.965/2014)	Princípios, garantias e deveres do uso da internet no Brasil
GDPR (UE 2016/679)	Proteção de dados na União Europeia
CCPA	California Consumer Privacy Act (EUA)

Resumo relâmpago (véspera da prova)

- Segurança da informação = proteger C-I-D (+ Autenticidade, Legalidade, Não repúdio, Rastreabilidade).
- CIDAL = Confidencialidade, Integridade, Disponibilidade, Autenticidade, Legalidade.
- Não repúdio e Rastreabilidade são complementares (fora da sigla).
- Auditoria (ISO 19011) = processo organizado, independente e registrado para checar conformidade a critérios.
- Auditor não conserta, só verifica e reporta.
- 5 benefícios da auditoria de SI: redução de riscos, segurança de dados, governança/conformidade, eficiência operacional, visão externa imparcial.
- Aplicar os princípios é proporcional ao risco — não é tudo ou nada.

Fonte: TERUEL, Evandro Carlos. *Segurança e auditoria de sistemas de informação*. São Paulo: Editora Senac São Paulo, 2026 (Capítulo 1). Resumo elaborado para fins de estudo.